COMP4127/COMP7850

Information Security

Security Management

Learning outcome:

After this lecture you should be able to:

1. Name a few threats to an organization.
2. Describe the basic concept of information security management in an organization.
3. Compare the differences between different levels of security policies.
4. Describe the basic concept of risk management about information security.

Threats to an organization

Security of an organization

Information security performs four important functions for an organization:

1. Protecting the organization 's ability to function
   - Each of an organization's communities of interest must address information security in terms of business impact and the cost of business interruption 阻断
2. Enabling the safe operation of applications running on the organization's IT system
   - Needs to create an environment that safeguards applications that are important elements of the organization's infrastructure — os, e-mail, IM etc
3. Protecting the data the organization collects and uses
   - The value of data motivates attackers to steal, sabotage, or corrupt it
4. Safeguarding the organization's technology assets
   - To perform effectively, organizations must employ secure infrastructure services appropriate to the size and scope of the enterprise

Threat of an Organization

	Category of Threat	Examples
1.	Compromises to intellectual property	Piracy, copyright infringement
2.	Software attacks	Viruses, worms, macros, denial of service
3.	Deviations in quality of service	ISP, power, or WAN service issues from service providers
4.	Espionage or trespass	Unauthorized access and/or data collection
5.	Forces of nature	Fire, flood, earthquake, lightning
6.	Human error or failure	Accidents, employee mistakes
7.	Information extortion	Blackmail, information disclosure
8.	Missing, inadequate, or incomplete	Loss of access to information systems due to disk drive failure without proper backup and recovery plan organizational policy or planning in place
9.	Missing, inadequate, or incomplete controls	Network compromised because no firewall security controls
10.	Sabotage or vandalism	Destruction of systems or information
11.	Theft	Illegal confiscation of equipment or information
12.	Technical hardware failures or errors	Equipment failure
13.	Technical software failures or errors	Bugs, code problems, unknown loopholes
14.	Technological obsolescence	Antiquated or outdated technologies

Compromises to Intellectual Property

知识产权.

Many organizations create or support the development of **intellectual property** (IP) as part of their business operations. IP includes trade secrets, copyrights, trademarks, patents. 专利

- **Software piracy** - Organizations often purchase or lease the IP of other organizations, and must abide by a purchase or licensing agreement for its use. Software piracy is when you fail to purchase or license the IP.
- **Copyright protection** - A number of technical mechanisms - digital watermarks, embedded code, copyright or activation codes, and even the intentional placement of bad sectors on software media have been used to enforce copyright laws. 部分.
- **User registration** - Users who install software are often asked or even required to register their software to complete the installation.

Espionage or Trespassing

间谍行动 侵入

香港浸會大學 HONG KONG BAPTIST UNIVERSITY

Espionage or trespassing is a well-known and broad category of electronic and human activities that can breach the confidentiality of information

机密数据.

- An unauthorized person gain access to protected information.

There are many form of espionage

- **Competitive intelligence**: using web browser to do market research - legal, not espionage
- **Shoulder surfing** when people gather information they are not authorized to have, e.g. at ATM, public computer, on bus when people use mobile phone, etc.
- **Trespassing**: enter a private location without permission.
- **Hacking**: enter a virtual premises without permission.

财产,场地.

Hacking

Hackers, people who do hackers can be divided into different types:

- Expect Hacker: mastering several programming languages, networking protocols, OS, etc who breaks in a system via exploiting different **system vulnerabilities**. They hack for personal benefit or benefit of an employer (crime organization/government).

新手

- Novice Hacker: having little or real expertise of their own, attacks by some automated exploits kits. They are referred as **script kiddies/packet monkeys**.

成套工具

Note:

持续存在的.

- Advanced Persistent Threat (APT) is a combination of social engineering, spear phishing, customized malware generated by nation-state sponsored organizations or sophisticated criminal operations.

恶意软件.

赞助者.

经验老道的.

Forces of Nature

Forces of nature can present some of the most dangerous threats because they usually occur with little warning and are beyond the control of people.

- Fire
- Flood
- Earthquake
- Lightning
- Landslide or mudslide
- Tornados or severe windstorms

Because it is not possible to avoid threats from forces of nature, organizations must implement controls to limit damage and prepare contingency plans and incident response plans.

意外事故.

Human Error or Failure

欺骗

- **Advance-Fee Fraud (AFF)**: typically conducted via e-mail, saying there is a large amount of money to give to you.
- **Phishing**: the attacker provides what appears to be a legitimate communication (usually email), but it contains hidden or embedded code that redirects the reply to a third-party site.
- **Social Engineering**: to gain system access or information that may lead to system access, e.g. knowing someones habits, physical locations, etc..
- **Spear phishing**: a special type of phishing that involves an attacker sending a targeted message that appears to be from an employer or a colleague that the victims knows.
- **Pretexting**: a purely social engineering attack in which the attacker calls a potential victim on the telephone and pretends to be an authority figure (immigration/SF Express).

Information Extortion 敲诈.

Information Extortion, also known as cyberextortion, is common in the theft of credit card numbers. An attacker or a trusted insider steals information from a computer system and demands compensation for its return or for an agreement not to disclose the information. 补偿

> 2010 Anthony Digati allegedly threatened to conduct a spam attack on the insurance company, New York Life, by sending out e-mails to company executives 行政 that he will send 6 million e-mails to people throughout the country to discredit 敗坏 the company. He asked for 3 million after the company paid him for 200,000.

Ransomware: the WannaCry attacks in 2017 triggered a global event that encrypt end-users documents/images and demand for a ransom paid in bitcoin.
赎金

WannaCry

Recycle Bin
Acrobat Reader DC
Wana Decrypt0r 2.0
Ooops, your files have been encrypted!
English
What Happened to My Computer?
Your important files are encrypted.
Many of your documents, photos, videos, databases and other files are no longer accessible because they have been encrypted. Maybe you are busy looking for a way to recover your files, but do not waste your time. Nobody can recover your files without our decryption service.
Can I Recover My Files?
Sure. We guarantee that you can recover all your files safely and easily. But you have not so enough time.
You can decrypt some of your files for free. Try now by clicking <Decrypt>.
But if you want to decrypt all your files, you need to pay.
You only have 3 days to submit the payment. After that the price will be doubled.
Also, if you don't pay in 7 days, you won't be able to recover your files forever.
We will have free events for users who are so poor that they couldn't pay in 6 months.
How Do I Pay?
Payment is accepted in Bitcoin only. For more information, click <About bitcoin>.
Please check the current price of Bitcoin and buy some bitcoins. For more information, click <How to buy bitcoins>.
And send the correct amount to the address specified in this window.
After your payment, click <Check Payment>. Best time to check: 9:00am - 11:00am
Payment will be raised on
5/22/2017 12:06:15
Time Left
02:23:59:47
Your files will be lost on
5/26/2017 12:06:15
Time Left
06:23:59:47
About bitcoin
How to buy bitcoins?
Contact Us
bitcoin ACCEPTED HERE
Send $300 worth of bitcoin to this address:
115p7UMMngoj1pMvkpHijcRdfJNXj6LrLn
Copy
Check Payment
Decrypt

Thinking against ransomware

勒索软件.

As part of the IT team of the organization, can you answer the following questions?

1. Should we pay the ransom?
2. What to do with the device?
3. Who did it?
4. Keep it secret or tell everyone?
5. How to get the data back?
6. What other things need to be done?

Thinking against ransomware

1. Should we pay the ransom? About one-third of the organization pay the ransom but almost half do not get their data back.
2. What to do with the device? Try to minimize the spread, take the compute off the network.
3. Who did it? Instead of locating the hacker (policing), find out who in the company misclick or which computer is exposed, stop the loophole and educate users.
   漏洞
4. Keep it secret or tell everyone? Alert all users as soon as possible to avoid the second wave. Better call them, circulate by other secure ways like phone call, meetings, posting memo, etc.
5. How to get the data back? Regularly backup is important. Clone them into a new device. This is also why container (docker) is important, isolating each service from each others.
6. Reimage the infected systems. If the ransomeware hacked in because of system vulnerability, this may happen to all computes. Recreate the master image with a secure system.

Sabotage or Vandalism 破坏行为

Attacks that deliberately destroy computer systems or businesses probably because of hatred, crime, revenge, or terrorism.

仇恨 报仇

In 2010, visitors to the Web site of the European Union presidency were redirected to a mock site that displayed an image of fictional character Mr. Bean.

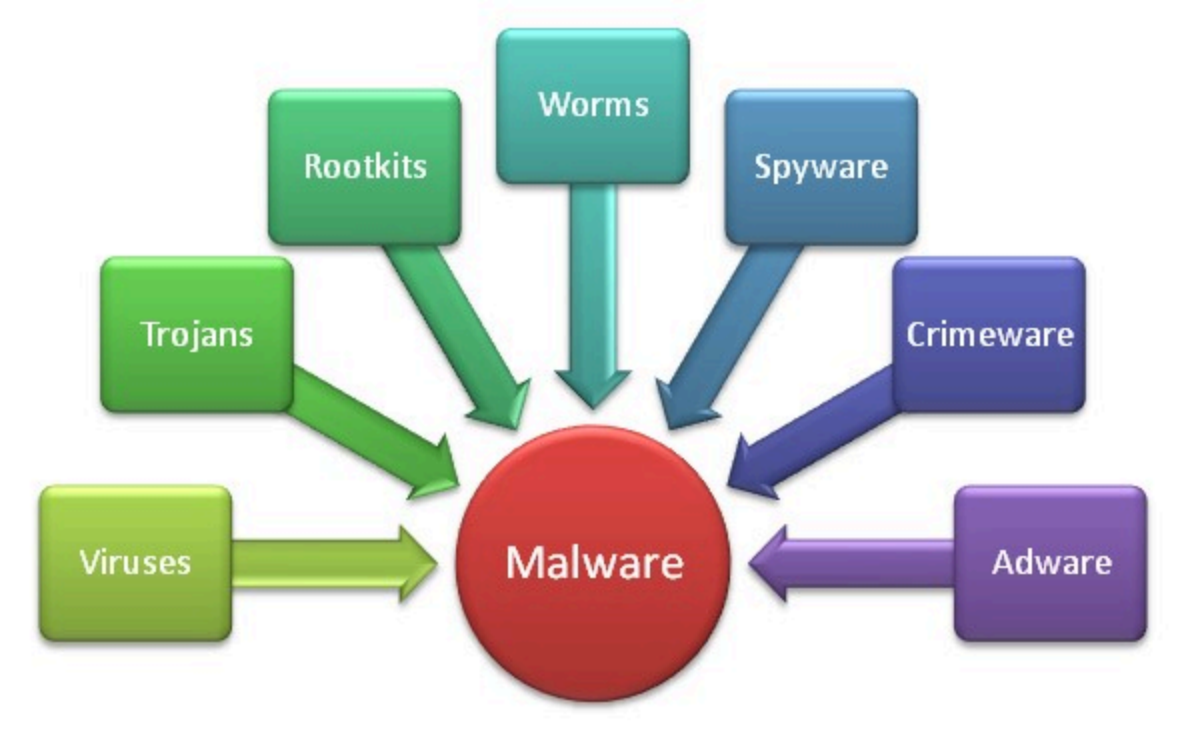
Organization can minimize their risk by backing up their web, closely monitoring, minimizing the use of exploitable software or API.

Software Attacks

故意的.

Deliberate software attacks occur when an individual or group designs and deploys software to attack a system. Once an infection occurs, the software leverages that foothold by attacking other systems that can be reached from the newly infected system.

杆杆 立足点.



Different types of malware

1. Virus - a code segment that attached to a program, when the program is execute, the virus will also be run. It will then infect other executables and spread.
2. Rootkits - it emphasizes the ability of "invisible" where it can hide itself from the task manager/process list.
3. Worm - a program that continue replicating itself until it completely fills available resources, such as RAM/hard drive/network bandwidth. Unlike virus it does not need to be executed by users.
4. Trojan horse - a legitimate looking program that allow attackers to remotely control the victim's machine.
5. Spyware - spying victims' activity and report that to the server.
6. Crimeware - an automatic tool that runs on a victims machine to commit a crime act.
7. Adware - constantly prompting Ads to user which disallow a user to remove it easily.

A Better Understanding of Security

A security system is only as strong as its weakest link. Consider:

- Applying a heavy duty doorlock to a camping tent??
- Office area with strong doorlock and false ceiling??
- Applying the strongest encryption technology to protect the password file in an un-patched computer system??

The weakest part will always break first, and be most attractive to attackers. Strengthening anything but the weakest link is useless

> 👩‍🏫 💬 Cryptography is usually not broken, but detoured.

绕道

Attack Tree

An attack tree is a security analysis tool used for analyzing the security of a system. It is a hierarchical tree structure such that:

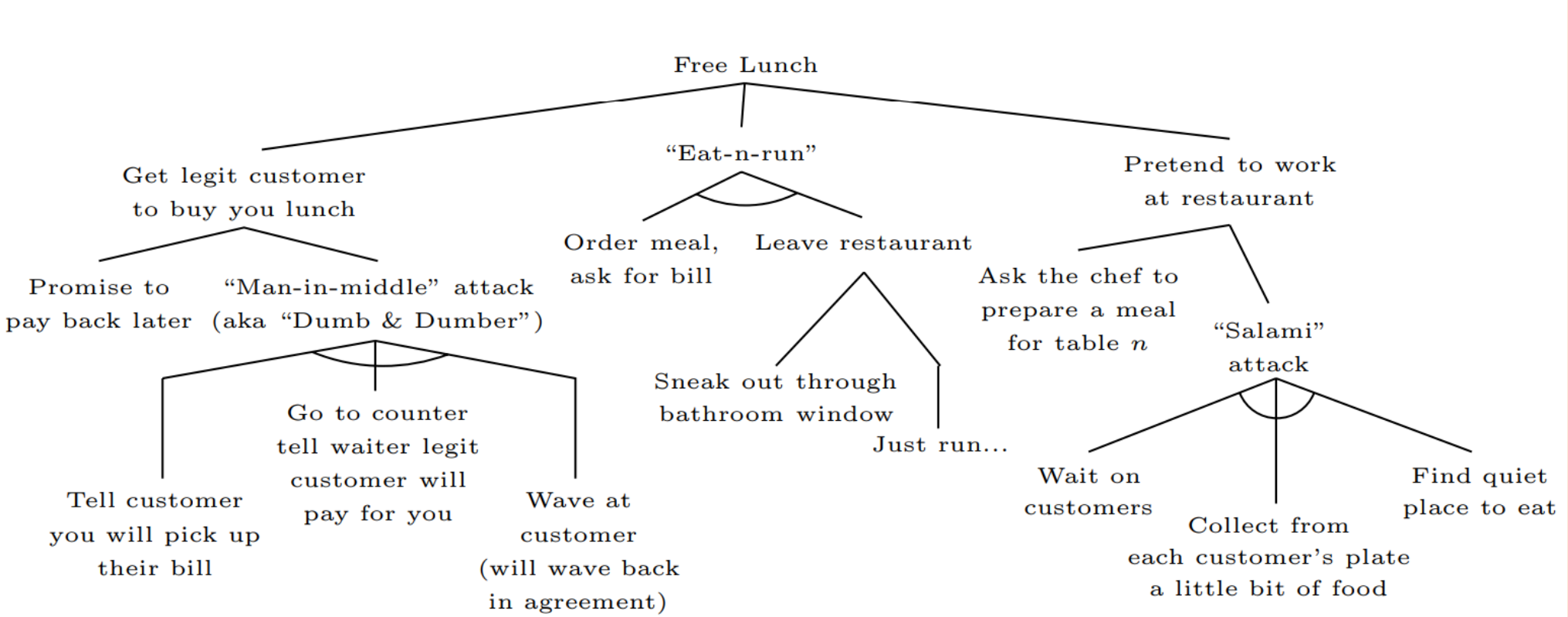
- Goal is root node
- Sub-goals are lower nodes/leaves
- Defines And/Or relationship between nodes
- Each nodes may contains attributes: Likelihood, equipment required, cost of attack, skill required, legality, etc.

Analysis from top/bottom.

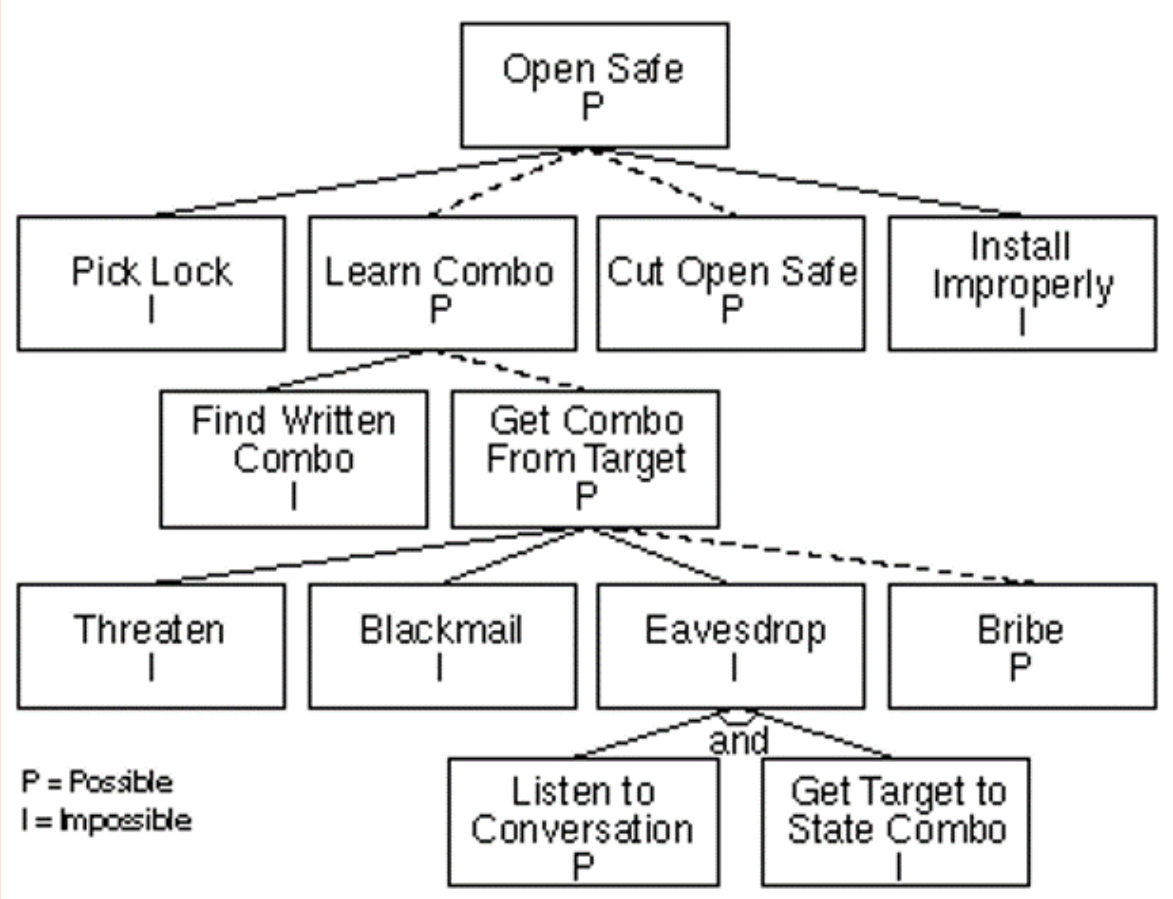
How to view a tree.

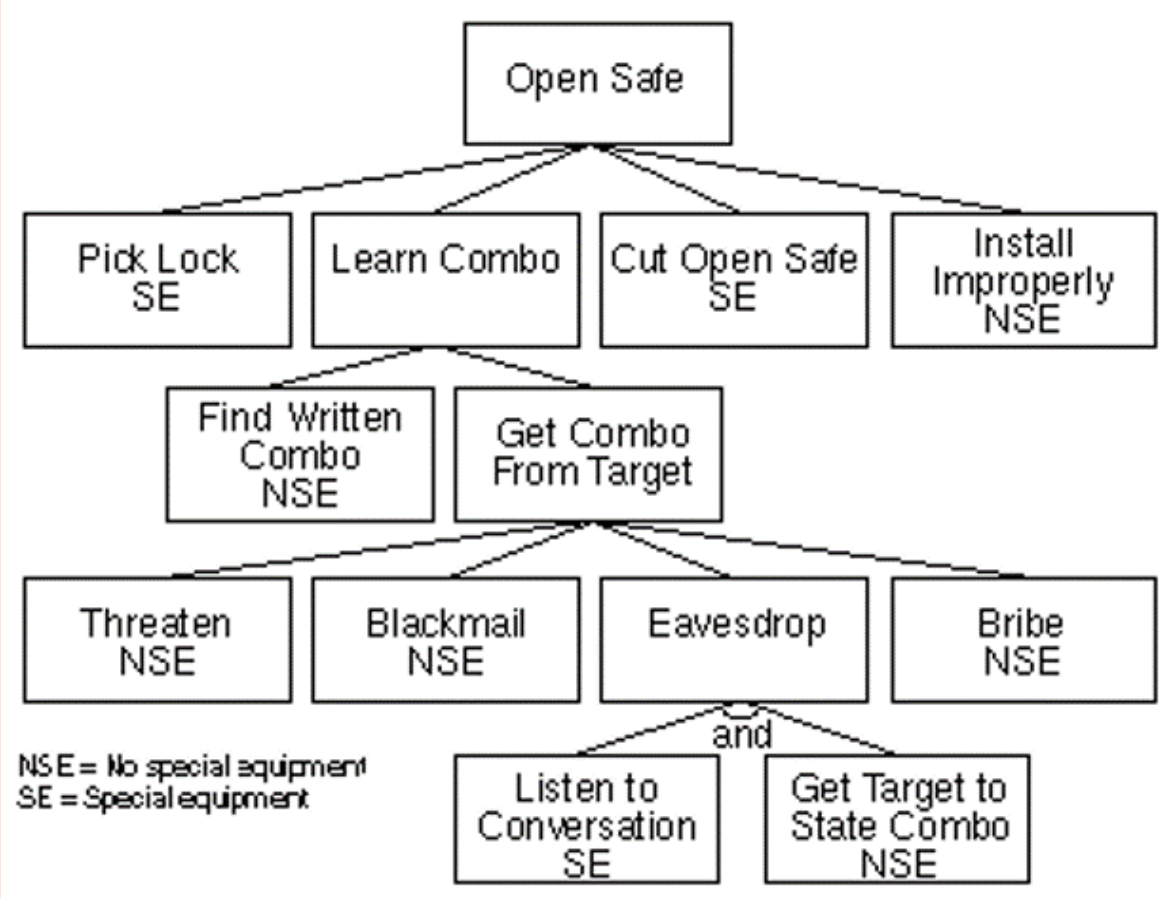
Attack Tree Example

Mauw, Sjouke, and Martijn Oostdijk. "Foundations of attack trees." International Conference on Information Security and Cryptology. Springer, Berlin, Heidelberg, 2005.



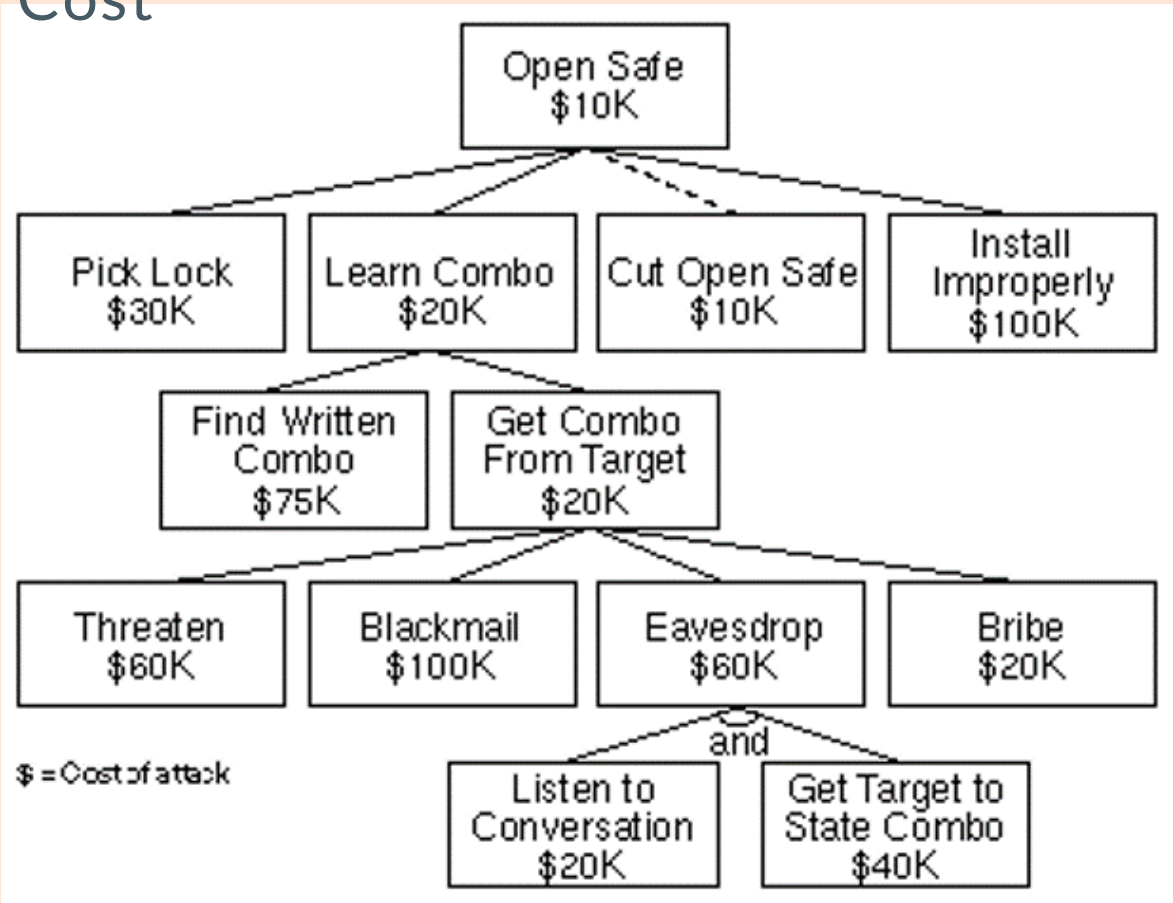
Attack Tree Example

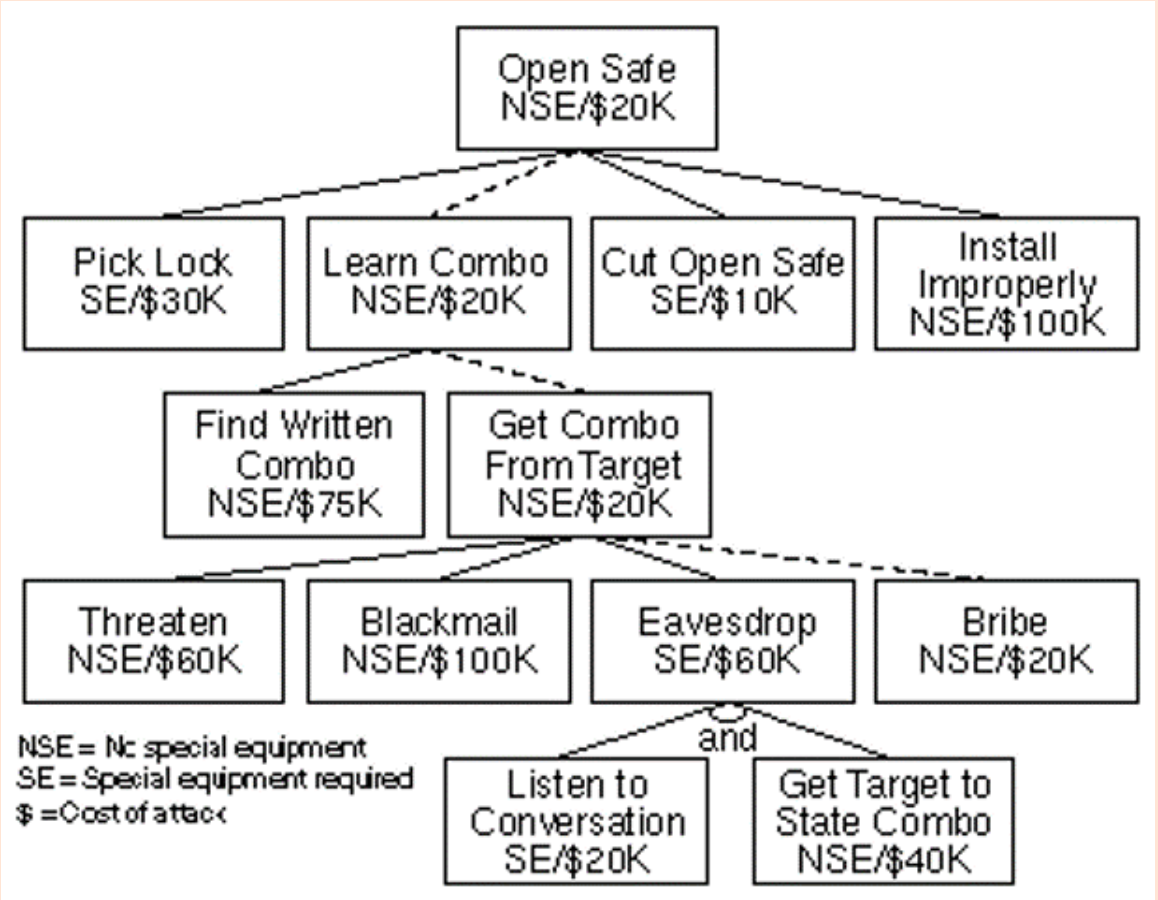




Attack Tree Example

Cost





The Weakest Link

- Attackers may not know what the weakest link is
- Different attackers may have different skills/tools in attacking a system, affecting the attack tree
- Different attackers may have different targets
- Different target implies a different attack tree

Security Management

Management and Leadership

In its most basic form, management involves using resources to get a job done. A manager has many roles to play within an organizations:

- Informational role - collecting, processing, and using information that can affect the completion of the objective.
- Interpersonal role - interacting with superiors, subordinates, outside stakeholders and other parties.
- Decisional role - selecting from among alternative approaches and resolving conflicts, dilemmas, or challenges

Governance

- For most organizations a very top of level (board/executive management) is responsible for the **governance** of the organization.
  - Board, CEO, CFO, COO, CIO, CISO, etc.

Governance is 統治

the set of **responsibilities and practices** exercised by the board and executive management with the goal of

- providing strategic direction,
- ensuring that objectives are achieved,
- ascertaining that risks are managed appropriately and, 查明
- verifying that the enterprise's resources are used responsibly

Information Security Governance

- **Information Security Governance** is governance in the context of information security.

Goals of information security governance

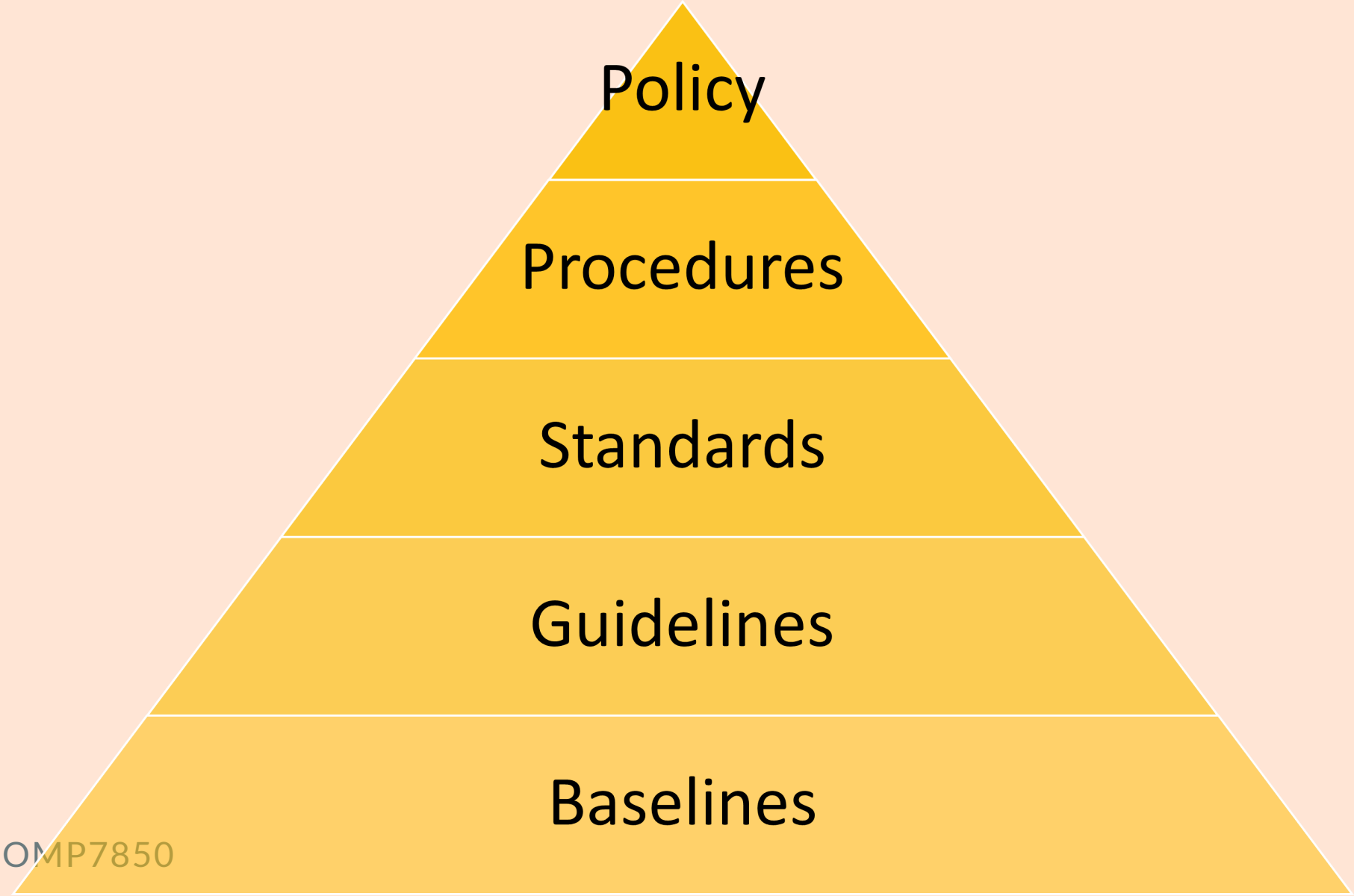
- **Strategic alignment** - aligning information security with the business strategy to support organizational objectives (e.g., growth, profitability)
- **Risk management** - executing apprpriate measures to manage and mitigate threats to information resources
- **Resource management** - utilizing information security knowledge and infrastructure efficiently and effectively
- **Performance measurement** - measuring, monitoring, and reporting information security governance metrics
- **Compliance** - ensuring that information security policies, procedures, and practices are in compliance with applicable laws, regulations, and standards

Information Security Governance

- It is also the organizational priority provided by senior leadership, which is required for a successful **information security program**.

> 👩‍🏫 💬 Information Security Program is a documented set of an organization's information security policies, procedures, standards, guidelines, and baselines.

Information Security Program



Policy

- Policies are high-level management directives. 指令
- Policy is mandatory
  - Even if you do not agree with your company's sexual harassment policy, you do not have the option of not following it.
- Policy is high level: it does not delve into specifics.

挖掘

A server security policy would discuss protecting the confidentiality, integrity, and availability of the system (usually in those terms).
But not use terms like “Linux” or “Windows”; that is too low level.

Components of Program Policy

All policy should contain these basic components:

- **Purpose** - describes the need for the policy, typically to protect the confidentiality, integrity, and availability of protected data.
- **Scope** - describes what systems, people, facilities, and organizations are covered by the policy.
- **Responsibilities** - include responsibilities of information security staff, policy and management teams, as well as responsibilities of all members of the organization.
- **Compliance** - describes two related issues: how to judge the effectiveness of the policies (how well they are working) and what happens when policy is violated (the sanction).

Policy Types

- **Enterprise Information Security Policy (EISP)** - a high-level information security policy that sets the strategic direction, scope, and tone for all of an organization's security efforts.
- **Issue-Specific Security Policy (ISSP)** - an organizational policy that provides detailed, targeted guidance to instruct all members of the organization in the use of a resource, such as one of its processes or technologies.
- **Systems-Specific Policy (SysSP)** - a policy that provides detailed, targeted guidance to instruct all members of the organization in the use of a specific system or technology.

Enterprise Information Security Policy (EISP)

- The EISP is a high-level information security policy that sets the strategic direction, scope, and tone for all of an organization's security efforts.
- Executive-level document, usually drafted by or with CIO of the organization
- Typically addresses compliance in two areas 承诺.
  - Ensure meeting requirements to establish program and responsibilities assigned therein to various organizational components
  - Use of specified penalties and disciplinary action

强制性的.

服从

Example: The EISP may state that the organization will comply with the data protection requirements of the European Union's Data Protection Directive (DPD) and that any employee who violates the policy will be subject to disciplinary action, up to and including termination of employment.

Issue-Specific Security Policy (ISSP)

- The ISSP is an organizational policy that provides detailed, targeted guidance to instruct all members of the organization in the use of a resource, such as one of its processes or technologies.
- Addresses specific areas of technology
- Requires frequent updates
- Contains statement on organization's position on specific issue

Example: The ISSP may state that all attachments to e-mail messages must be encrypted and that any employee who violates the policy will be subject to disciplinary action, up to and including termination of employment.

Systems-Specific Policy (SysSP)

- The SysSP is an organizational policy that often functions as standards or procedures to be used when configuring or maintaining systems.
- Systems-specific policies fall into two groups:

1. Access control lists (ACLs) consists of the access control lists, matrices, and capability tables governing the rights and privileges of a particular user to a particular system.
2. Configuration rules comprise the specific configuration codes entered into security systems to guide the execution of the system.

Example: The SysSP may state that a web server must be configured to use HTTPS and that any employee who violates the policy will be subject to disciplinary action, up to and including termination of employment.

Procedures

- A procedure is a step-by-step guide for accomplishing a task.
- They are low level and specific.
- Like policies, procedures are mandatory.

Example - Procedure for creating a new user

1. Receive a new-user request form and verify its completeness.
2. Verify that the user's manager has signed the form.
3. Verify that the user has read and agreed to the user account security policy.
4. Classify the user's role by following role-assignment procedure NX-103.
5. Verify that the user has selected a "secret word," such as their mother's maiden name, and enter it into the help desk account profile.
6. Create the account and assign the proper role.
7. Assign the secret word as the initial password, and set "Force user to change password on next login to 'True'."
8. Email the New Account document to the user and their manager.

It is mandatory. System admin cannot skip step 3 for example.

Standards

- A standard describes the specific use of technology, often applied to hardware and software.
  - “All employees will receive an ACME Nexus-6 laptop with 16 gigabytes of memory, a 4.0 GHZ CPU, and one-terabyte disk” is an example of a hardware standard.
  - “The laptops will run Windows 11 Professional, 64-bit version” is an example of a software (operating system) standard.
- Standards are mandatory.
- They lower the Total Cost of Ownership of a safeguard.
- Standards also support disaster recovery.

Guidelines

- A guideline can be a useful piece of advice. 任意的
- Guidelines are recommendations (which are discretionary).

Example

- To create a strong password, take the first letter of every word in a sentence, and mix in some numbers and symbols. ‘I will pass the CISSP® exam in 6 months!’ becomes ‘Iwptcei6m!’
- You can create a strong password without following this advice, which is why guidelines are not mandatory. They are useful, especially for novice users.

Baseline

一致的

- Baselines are uniform ways of implementing a standard.
  - “Harden the system by applying the Center for Internet Security Linux benchmarks” is an example of a baseline. The system must meet the baseline described by those benchmarks.

标准

变强壮

- Baselines are discretionary: it is acceptable to harden the system without following the aforementioned benchmarks, as long as it is at least as secure as a system hardened using the benchmarks.
- Formal exceptions to baselines will require senior management sign-off.

Summary

Document	Example	Mandatory or discretionary?
Policy	Protect the CIA of PII by hardening the operating system	Mandatory
Procedure	Step 1: Install pre-hardened OS Image. Step 2: Download patches from update server. Step 3: ...	Mandatory
Standard	Use Nexus-6 laptop hardware	Mandatory
Guideline	Patch installation may be automated via the use of an installer script	Discretionary
Baselines	Use the CIS Security Benchmarks Windows Benchmark	Discretionary

Policies, Standards, and Practices

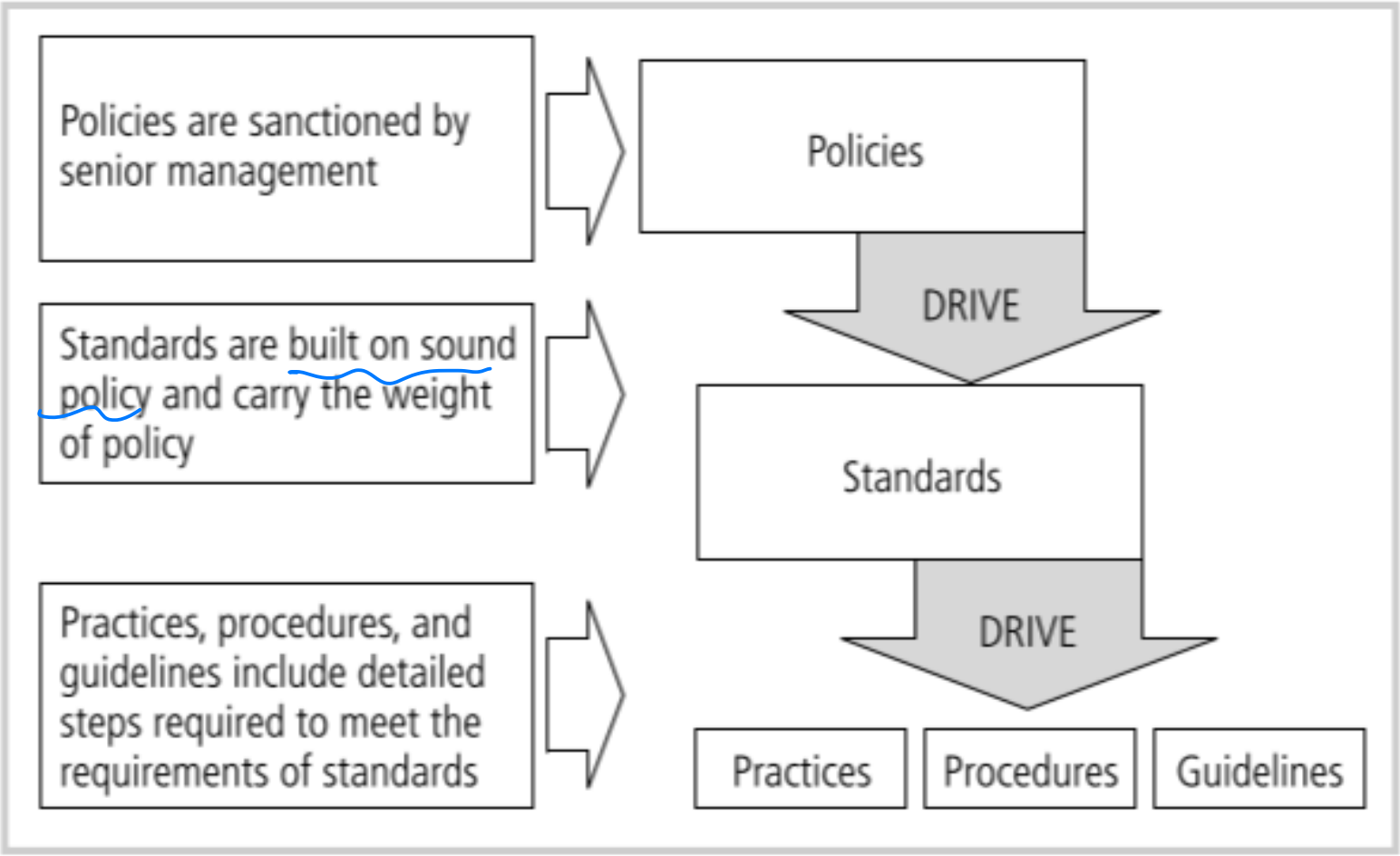


Figure 5-1 Policies, Standards, and Practices

Source: Course Technology/Cengage Learning

InfoSec at different levels

InfoSec Governance Responsibilities

統治.

Responsibilities	Functional Role Examples
• Oversee overall Corporate Security Posture (Accountable to Board) • Brief board, customers, and other stakeholders	• Chief Executive Officer
• Set security policy, procedures, program, training for company • Respond to security breaches (investigate, mitigate, litigate) • Responsible for independent annual audit coordination • Implement/audit/enforce/assess compliance	• Chief Information Security Officer • Chief Information Officer • Chief Risk Officer • Department Head
• Communicate policies, program (training)	• Mid-level manager
• Implement policy, report security vulnerabilities and breaches	• Enterprise staff/ employees

InfoSec Governance Responsibilities

公告. 董事 管理

Boards of directors supervise strategic InfoSec objectives by:

1. Creating and promoting a culture that recognizes the criticality of information and InfoSec to the organization

匹配

2. Verifying that management's investment in InfoSec is properly aligned with organizational strategies and the organization's risk environment
3. Mandating and assuring that a comprehensive InfoSec program is developed and implemented
4. Requiring reports from the various layers of management on the InfoSec program's effectiveness and adequacy

Strategic planning

Strategic planning is the process of defining and specifying the long-term direction (strategy) to be taken by an organization, and the allocation and acquisition of resources needed to pursue this effort.

获得 追求

1. Identifies a goal for an area of improvement or a need for a new capability and documents the current progress toward accomplishing that goal (where are we now?);
2. Leadership articulates where the organization seeks to be with regard to the goal (where are we going?);
3. Plans can be made for how to achieve that goal (how will we get there?).

Creating a strategic plan

- After an organization develops a general strategy, it must create an overall strategic plan by extending that general strategy into specific strategic plans for major divisions.
- For example, a CEO might develop the following general strategy and goals:
  - **Strategy**: To provide the highest-quality, most cost-effective widgets in the industry.
  - **Goal**: To increase revenue by 10 percent annually, market share by 5 percent annually.

收入

Creating a strategic plan (con't)

The CIO/COO/CFO (C's level) extend it to:

- **Strategy**: To provide high-level, cost-effective information service in support of the highest-quality, most cost-effective widgets in the industry.
- **Goal**:
  - To reduce IT-related expense by 5 percent annually while maintaining systems, networks, and service capabilities to meet business needs.
  - To support corporate reduction in the cost of production through cost-effective system development.
  - To recruit and retain competent IT professionals.

Creating a strategic plan (con't)

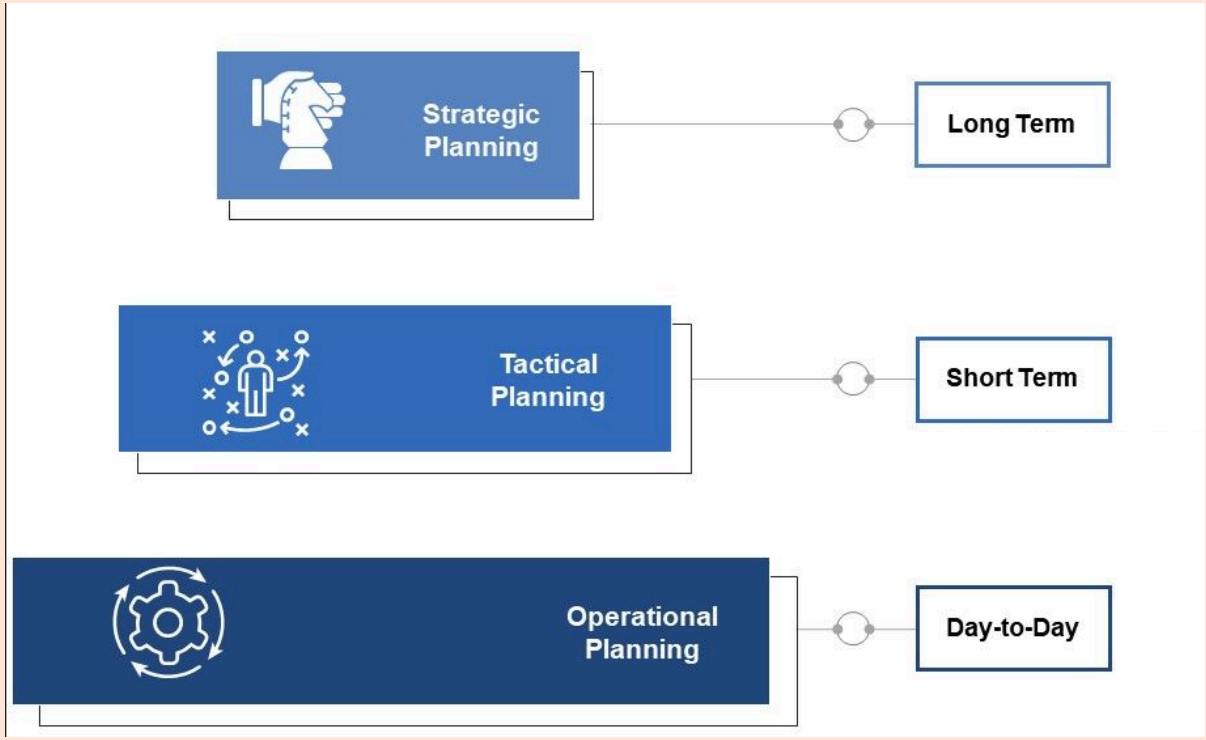
The CISO (Chief Information Security Officer, under CIO) further extends it to:

- **Strategy**: To provide effective information service at minimal cost in support of the highest quality, most cost-effective widgets in the industry.
- **Goal**:
  - To reduce cost associated with information breaches to near zero through improved security assessments and controls;
  - To support IT reduction in the cost of new information security technologies and systems through the implementation of 20 percent use of open source solutions;
  - To support improvements in all business units through improved security measures that support research and development without concern over the loss of intellectual property due to corporate espionage

It relies on the executive's ability to know and understand the strategic goals of the entire organization, to know and appreciate the strategic and tactical abilities of each unit within the organization, and to negotiate with peers and superiors.

Plans

- Strategic plans will be translated to **tactical plans** which has a more ~~short-term focus~~ (e.g. duration of one year). A strategic goal are broken down into incremental objectives.
- Tactical plans includes: budgeting, 预算, resource allocation, personnel, etc.
- Managers and employees use **operational plans** which derived from tactical plans. These plan include day-to-day performance of tasks.



- Operational plans includes: configuration of hardware, design and implementation of security education program, etc.

Risk Management

Risk Analysis

- Accurate Risk Analysis is a critical skill for an information security professional.
- We must hold ourselves to a higher standard when judging risk.
- Our risk decisions will dictate 指令 which safeguards we deploy to protect our assets, and the amount of money and resources we spend doing so.
- Poor decisions will result in wasted money, or even worse, compromised data.

Risk by Nick Youngson CC BY-SA 3.0 Pix4free.org

Risk Management

Risk Management is a series of task to understand, measure, and response to risk.

- Identify and characterize threats
- 评估 Assess vulnerability of critical assets 财产. to specific threats
- Determine the probability of risks and their impact
- Identify ways to reduce risks
- Prioritize risk reduction measures 优先考虑
- Continuously monitor risk factors

Threats, Vulnerabilities, and Impact

- A **threat** is a potentially harmful occurrence
- A **vulnerability** is a weakness in a system that can be exploited by a threat.
- An **impact** is the effect of a threat on an asset. 对了

Examples of threats

- earthquake
- power outage
- a network attack

Examples of vulnerabilities

- buildings that are not built to withstand earthquakes,
- a data center without proper backup power,
- an operating system that has not been patched in a few years.

Examples of impacts

- loss of life
- loss of data
- compromise of sensitive information

Risk = Threat × Vulnerability x Impact

- Risk is determined by the **likelihood of a threat**, exploiting a system **with certain level of vulnerability** and resulting some **severity of impact**.
- Sometimes we are able to quantify the likelihood of a threat, the vulnerability of a system, and the impact of an threat.

Example

Compared to Boston, the threat of an earthquake in San Francisco is higher (more frequent earthquakes), but the vulnerability is lower (stronger seismic safety building codes). Boston has a denser population, so the impact of an earthquake is higher.

Factors	Boston	San Francisco
Threat	2	4
Vulnerability	4	2
Impact	3	1
Risk	24	8

Risk Matrix

- A risk matrix is a set of categories that define the probability of a risk occurring.
- It uses a simple mechanism that categorizes the severity of the risk, i.e. Critical, Marginal, and Negligible.
- Matched with the probability of that risk occurring, i.e. Definitely, Likely, Possibly, and Unlikely.

From Queensland Goverment, Australia

Risk and Risk Mx

	Consequence				
Likelihood	Insignificant	Minor	Moderate	Major	Critical
Rare	LOW Accept the risk Routine management	LOW Accept the risk Routine management	LOW Accept the risk Routine management	MEDIUM Specific responsibility and treatment	HIGH Quarterly senior management review
Unlikely	LOW Accept the risk Routine management	LOW Accept the risk Routine management	MEDIUM Specific responsibility and treatment	MEDIUM Specific responsibility and treatment	HIGH Quarterly senior management review
Possible	LOW Accept the risk Routine management	MEDIUM Specific responsibility and treatment	MEDIUM Specific responsibility and treatment	HIGH Quartely senior management review	HIGH Quarterly senior management review
Likely	MEDIUM Specific responsibility and treatment	MEDIUM Specific responsibility and treatment	HIGH Quarterly senior management review	HIGH Quarterly senior management review	EXTREME Monthly senior management review
Almost certain	MEDIUM Specific responsibility and treatment	MEDIUM Specific responsibility and treatment	HIGH Quarterly senior management review	EXTREME Monthly senior management review	EXTREME Monthly senior management review

Example of Likelihood

Likelihood scale	Criteria	Description
Rare	0 - 5%	Extremely unlikely or virtually impossible
Unlikely	6 - 25%	Unlikely to occur
Possible	26 - 50%	Fairly likely to occur
Likely	51 - 75%	More likely to occur
Almost certain	>75%	Almost certain will occur

Example of Impacts

香港浸會大學 HONG KONG BAPTIST UNIVERSITY

Type of impact	Insignificant	Minor	Moderate	Major	Critical
Impact to cost	<$150k	$150k - $500k	$500k - $1.5m	$1.5m - $5m	>$5m
Impact to time	<10 days	10 - 20 days	20 - 40 days	40 - 60 days	>60 days
Impact to scope	Minor change in ancillary requirements	Change in ancillary requirements	Change in multiple requirements	Change in any of the crital requirements	Major change in any of the critical requirements

Annualized Loss Expectancy (ALE)

The Annualized Loss Expectancy (ALE) calculation allows you to determine the annual cost of a loss due to a risk. Once calculated, ALE allows you to make informed decisions to mitigate the risk.

緩和

An example of risk due to lost or stolen unencrypted laptops. Assume your company has 1000 laptops that contain Personally Identifiable Information (PII).

HOW

The Information Security Blueprint

- Basis for design, selection, and implementation of all security policies, education and training programs, and technological controls
- More detailed version of security framework (outline of overall information security strategy for organization)
- Should specify tasks to be accomplished and the order in which they are to be realized
- Should also serve as scalable, upgradeable, and comprehensive plan for information security needs for coming years

Security Policies in different categories

Information Policy

- Defines what sensitive information is within the organization, and how it should be protected

Security Policy

- Defines the technical requirements for security on computer systems and network equipment

Computer Use Policy

- Rules like who may use computer systems, how they may be used and when

Security Policies in different categories

Internet Use Policy

- Defines the appropriate uses of the Internet (may also define inappropriate uses of it too)

E-mail Policy

- Defines the proper use of email (internal and external communication)

User Management Procedures

- Defines the policy of user account creation, deletion and change of role

Security Policies in different categories

System Administration Procedures

- Defines how various security/system administration procedures (e.g., software upgrade, vulnerability scans, log review, etc.)

Backup Policy

- Defines how system backups are to be performed and managed

Incident Response Procedures

- Defines how the organization will react when a computer security incident occurs

Security Policies in different categories

配置

Configuration Management Procedure

- Defines the steps that will be taken to modify the state of the organization's computer systems, network devices, and software systems

Design Methodology

- Defines the steps that the organization should follow to create a new project/system into production

Disaster Recovery Plans

- Defines the handling of disasters (e.g., fires, floods, site-destroying events)

Security Best Practices

- User security awareness training
- Security assessment & **audits** 审计
- Reviewing security policies and procedures

ISO/IEC 27001 specifies a management system that is intended to bring information security under management control and gives specific requirements. Organizations that meet the requirements may be certified by an accredited certification body following successful completion of an audit. 公认的

ISO/IEC 27001

- Includes 10 requirements:
  1. Scope of the standard
  2. How the document is referenced
  3. Reuse of the terms and definitions in ISO/IEC 27000
  4. Organizational context and stakeholders
  5. Information security leadership and high-level support for policy
  6. Planning an information security management system; risk assessment; risk treatment
  7. Supporting an information security management system
  8. Making an information security management system operational
  9. Reviewing the system's performance
  10. Corrective action

Law and Regulation

Legal Issue of Information Security

香港浸會大學
HONG KONG BAPTIST UNIVERSITY

Several laws govern information security:

- Cap 486 - The Personal Data (Privacy) Ordinance (pcpd.org.hk) 法令
- section 161 of the Crimes Ordinance (Cap. 200) - Access to Computer with Criminal or Dishonest Intent

Cap 486 - history

- The Personal Data (Privacy) Ordinance (the "PDPO") was passed in 1995 and took effect from December 1996

供应

- In 2012, the introduction of **direct marketing provisions** and other additional protection to cope with new privacy challenges and address public concerns. In 2021, the PDPO underwent another major amendments. The amendments aim to combat **doxxing** acts

修正

Key Definition

- **Personal Data** means information which relates to a living individual and can be used to identify that individual. It must also exist in a form which access to or processing of is practicable.
- **Data Subject** is the individual who is the subject of the personal data.
- **Data User** is a person who, either alone or jointly with other persons, controls the collection, holding, processing or use of personal data.
- **Data Processor** is a person who processes personal data on behalf of another person (a data user), instead of for his/her own purpose(s). Data processors are not directly regulated under the PDPO. Instead, data users are required to, by contractual or other means, ensure that their data processors meet the applicable requirements of the PDPO.

合同的

DPPs

DPP1 - Purpose and Manner of Collection

The data collected should be necessary and adequate but not excessive for such purpose. The means of collection should be lawful and fair.

DPP2 - Accuracy and Duration of Retention 保留

Data users has to ensure that personal data is accurate and is not kept longer than is necessary for the fulfillment of the purpose for which the data is used.

DPP3 - Use of Data

Prohibits the use of personal data for any new purpose which is not or is unrelated to the original purpose when collecting the data, unless with the data subject's express and voluntary consent.

同意

DPPs

DPP4 - Data Security

Data users have to protect the personal data they hold against unauthorised or accidental access, processing, erasure, loss or use.

DPP5 - Openness and Transparency

Data users to take all practicable steps to ensure openness of their personal data policies and practices, the kind of personal data held and the main purposes for holding it.

DPP6 - Access and Correction

Data subjects has the right to request access to and correction of their own personal data.

European Union Data Protection Directives

Directive 95/46/EC

- Passed European Parliament 24 October 1995
- Goal is to ensure free flow of information
- Must preserve privacy needs of member states

Provides guidelines for member state legislation 制定法律.

- Not directly enforceable

Forbids sharing data with states that don't protect privacy

- Non-member state must provide adequate protection,
- Sharing must be for "allowed use", or
- Contract Enforcements ensure adequate protection

EU 95/46/EC

- Personal data is any information that can be traced directly or indirectly to a specific person
- Use allowed if:
  - Unambiguous consent given
  - Required to perform contract with subject
  - Legally required
  - Necessary to protect vital interests of subject
  - In the public interest, or
  - Necessary for legitimate interests of processor and doesn't violate privacy

EU 95/46/EC

Some uses specifically proscribed 禁止

- Can't reveal racial/ethnic origin, political/religious beliefs, trade union membership, health/sex life

Must make data available to subject

- Allowed to object to such use
- Must give advance notice / right to refuse direct marketing use

Limits use for automated decisions (e.g., creditworthiness) 信贷度

- Person can opt-out of automated decision making
- Onus on processor to show use is legitimate and safeguards in place to protect person's interests
- Logic involved in decisions must be available to affected person

Reference

- Chapter 1, “Cryptography and Network Security” (4th Ed.) by William Stallings, published by Prentice Hall (2006)
- “Network Security: A Beginner's Guide” (2nd Ed.) by Eric Maiwald, published by McGraw-Hill Osborne Media (2003)
- “2005 FBI Computer Crime Survey” by Federal Bureau of Investigation (FBI), United States (http://www.fbi.gov/publications/ccs2005.pdf)
- “Hacking the Industrial Network” by Innominate Security Technologies (http://www.remotemagazine.com/images/PContact-Hacking.pdf)
- CERT Statistics (Historical), US-CERT (http://www.cert.org/stats/)
- ITIL Risk Management Tutorial (https://www.itiltraining.com/blog/2019/05/30/risk-management/)